

RED TEAM LEARNING PATH

MODULE 06

Pentest Methodology, Scope & Rules of Engagement

Omarchy / Arch Linux Edition

*Lifecycle engagement yang akan dipakai sepanjang kurikulum***Fokus modul**

Belajar menjalankan penetration test sebagai engagement profesional: authorization, tujuan, scope, Rules of Engagement (RoE), test plan, communication, evidence handling, change control, cleanup, dan handoff. Modul ini sengaja menahan aktivitas teknis ofensif sampai boundary tertulis jelas.

Repository: github.com/VaxXinE/red-teaming

Versi 1.0 - 04 Oktober 2026

Cara Menggunakan Modul Ini

Module 00-05 membangun fondasi teknis. Module 06 membangun fondasi engagement. Banyak kegagalan pentest bukan karena tester tidak tahu command, tetapi karena target salah, window tidak jelas, emergency contact tidak ada, data handling buruk, atau scope berubah tanpa approval. Di production, disiplin administratif adalah kontrol keselamatan teknis.

0.1 Learning Objectives

- [] Bedakan objective, scope, Rules of Engagement, test plan, dan report deliverables.
- [] Bisa membuat scope matrix yang eksplisit: in-scope, out-of-scope, discovered/unknown.
- [] Bisa menulis allowed/prohibited techniques dan stop conditions yang dapat dieksekusi.
- [] Bisa merancang communication/escalation path serta testing window.
- [] Bisa menangani evidence secara minimal, terlabel, hashed, dan sesuai retention agreement.
- [] Bisa mengenali scope creep dan membuat change request sebelum melanjutkan.
- [] Bisa membuat engagement pack yang siap dipakai untuk lab atau simulasi internal.

LEGAL & AUTHORIZATION

Modul ini adalah panduan engineering, bukan nasihat hukum. Authorization harus datang dari pihak yang memang berwenang atas aset. Kontrak, privasi, data residency, labor law, cloud/SaaS terms, dan kewajiban notifikasi harus diverifikasi sesuai organisasi dan yurisdiksi.

0.2 Tools pada Module 06

Tool	Peran	Kenapa dipakai
Markdown / text editor	Scope, RoE, notes, templates	Portable, diffable, mudah direview
Git	Versioning dokumen engagement	Audit perubahan; jangan commit secret/evidence sensitif
Python 3	Validasi struktur scope + activity log	Standard library cukup untuk training
sha256sum	Evidence manifest	Mendeteksi perubahan byte pada evidence
Omarchy terminal	Workspace & automation	Lingkungan utama kita

1. Pentest adalah Engagement, Bukan Sekadar Serangkaian Serangan

Penetration test adalah assessment dengan tujuan, pemilik risiko, boundary, waktu, teknik, bukti, dan deliverable. NIST SP 800-115 membahas planning, execution, data handling, findings, dan reporting; Appendix B-nya menyediakan template Rules of Engagement. CPENT juga menaruh scoping, RoE, legal considerations, test plan, dan scope creep di area engagement planning.



Siklus kerja: authorization -> scope -> execution -> evidence -> report -> cleanup

Mindset

Sebelum bertanya "tool apa yang dipakai?", tanyakan: siapa yang memberi izin, aset apa yang dimiliki pihak tersebut, objective apa, kapan boleh testing, apa yang dilarang, dan siapa yang menerima risiko jika service terganggu.

2. Lima Dokumen yang Sering Tertukar

Dokumen / Konsep	Menjawab pertanyaan	Contoh isi
Authorization	Siapa yang memberi hak melakukan test?	owner, approver, tanggal, aset/organisasi
Statement of Work / SOW	Apa pekerjaan komersial/operasionalnya?	scope high-level, timeline, deliverable, assumptions
Scope	Aset mana yang boleh/tidak boleh disentuh?	CIDR, FQDN, app, tenant, account, exclusions
Rules of Engagement / RoE	Bagaimana test boleh dilakukan?	window, teknik, rate, stop condition, contacts
Test Plan	Urutan eksekusi teknisnya bagaimana?	phases, dependencies, checkpoints, tools/categories

Common mistake

Scope menjawab "where/what"; RoE menjawab "how/when/under what constraints". Menulis sebuah IP di scope tidak otomatis berarti semua teknik terhadap IP itu diizinkan.

3. Authorization: Bukti Izin Harus Mendahului Testing

Authorization sebaiknya eksplisit dan dapat ditelusuri. Untuk perusahaan, pihak yang meminta test belum tentu memiliki authority atas semua aset yang disebut. Third-party hosting, SaaS, partner network, subsidiary, acquired company, dan cloud account dapat punya owner/terms berbeda.

- [] Identitas pihak yang memberi izin jelas.
- [] Aset/organisasi yang dicakup disebut atau dirujuk ke scope version tertentu.
- [] Periode authorization jelas.
- [] Ada emergency/stop contact.
- [] Third-party dependency diidentifikasi dan approval tambahan dicatat bila perlu.
- [] Approval tersimpan di lokasi yang dapat dirujuk tim testing.

No implicit authorization

"Domain-nya milik perusahaan" belum tentu cukup. CDN, payment provider, SSO tenant, SaaS, managed service, dan shared cloud infrastructure dapat berada di bawah pihak lain.

4. Objectives dan Success Criteria

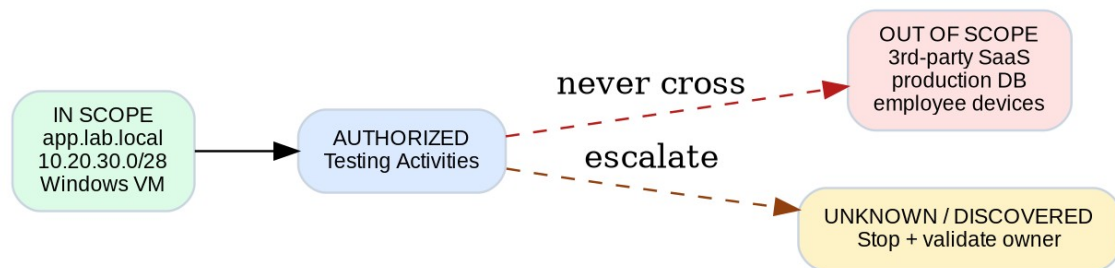
Objective mendefinisikan apa yang ingin dipelajari pemilik sistem. Tanpa objective, tester mudah berubah menjadi "cari sebanyak mungkin vulnerability" tanpa hubungan dengan business risk. Success criteria membuat engagement berhenti pada kondisi yang cukup, bukan terus memperluas dampak.

Objective buruk	Objective lebih operasional
Hack aplikasi kami	Evaluasi apakah user biasa dapat mengakses data milik user lain pada environment staging.
Test network internal	Validasi apakah workstation lab dapat mencapai asset tier server di luar segment yang diizinkan.
Coba Active Directory	Identifikasi attack path dari user lab low-privilege menuju administrative control tanpa melakukan destructive changes.

Proof, not damage

Tujuan pentest adalah membuktikan risiko dengan impact minimum yang cukup. Jika satu proof aman sudah membuktikan masalah, tidak perlu memperbesar blast radius hanya untuk menunjukkan kemampuan.

5. Scope Engineering: Aset, Boundary, dan Ownership



Scope bukan sekadar list target - ia juga mendefinisikan apa yang harus dihentikan dan dieskalasikan

Representasikan scope dengan identifier yang stabil. Untuk network gunakan IP/CIDR; untuk web gunakan FQDN/URL dan environment; untuk cloud gunakan account/subscription/project/tenant ID; untuk mobile gunakan package/bundle identifier dan backend scope. Hindari istilah ambigu seperti "semua server terkait" tanpa inventory.

Asset type	Identifier yang baik	Catatan penting
Network	10.20.30.0/28	Pastikan bukan shared/third-party range
Web	https://staging.example.invalid	Bedakan staging vs production
Cloud	AWS account 123456789012	Scope service/region bila perlu
AD	lab.example.invalid forest	Nyatakan trust/domain exclusions
API	https://api.staging.example.invalid/v1	Nyatakan tenant/test account
Endpoint	asset IDs / dedicated VMs	Hindari employee personal device

Discovered asset rule

Kalau saat recon ditemukan subdomain/IP baru yang tidak tercantum, jangan otomatis menganggap in-scope. Catat, validasi ownership, minta change approval, baru lanjut.

6. Rules of Engagement (RoE): Guardrail Eksekusi

RoE mengubah intent menjadi operational constraints. RoE harus cukup spesifik sehingga tester pada jam 02:00 tetap tahu apakah suatu tindakan boleh dilakukan tanpa menebak.

Area RoE	Contoh keputusan
Testing window	09:00-17:00 WIB atau 24x7
Source addresses	IP/VPN tester yang akan terlihat di logs
Authentication	test accounts, MFA handling, account lockout limits
Automation/rate	max concurrency/request rate bila diperlukan
DoS/stress	prohibited kecuali exercise terpisah
Credential attacks	allowed? spray? lockout threshold? approved accounts?
Social engineering	explicit channel/persona/targets atau prohibited
Persistence	prohibited / allowed only with named method and cleanup

Data access	minimum proof; no bulk download of real data
Destructive action	delete/modify records prohibited
Stop condition	outage, sensitive data, ambiguity, incident declaration

High-risk techniques need explicit words

DoS, destructive changes, persistence, broad credential attacks, phishing, physical access, cloud control-plane changes, and collection of real sensitive data sebaiknya tidak pernah diasumsikan dari izin pentest umum.

7. Testing Window, Safety Budget, dan Rate

Window menentukan kapan active testing boleh terjadi. Safety budget menentukan seberapa agresif test boleh dilakukan. Rate/concurrency bukan angka universal; ia harus mengikuti capacity target dan objective. Untuk service production, default conservative dan observability/rollback harus siap.

- Bedakan passive observation dengan active requests jika window berbeda.
- Catat timezone secara eksplisit; jangan menulis hanya "09:00-17:00".
- Tentukan blackout period: payroll, deploy, settlement, month-end, campaign besar.
- Tentukan lockout-sensitive activity dan max attempts berdasarkan policy target.
- Tentukan siapa yang boleh meminta pause/resume.

8. Communication & Escalation

Engagement harus punya jalur komunikasi normal dan emergency. Tester perlu tahu kapan memberi update, kapan berhenti, dan kapan incident response mengambil alih. Jangan bergantung pada satu orang yang mungkin sedang offline.

Event	Action
Normal progress	Status sesuai cadence, mis. daily checkpoint
Potential critical finding	Verify minimally -> notify agreed contact -> await guidance if impact can grow
Service degradation	Stop related activity -> collect minimal evidence -> emergency contact
Out-of-scope asset discovered	Do not test -> record -> request scope decision
Possible real attacker activity	Pause conflicting actions -> preserve notes -> coordinate with owner/IR
Credential/sensitive data encountered	Minimize access -> protect evidence -> notify per data-handling plan

Attribution problem

Blue Team dapat mengira tester adalah real attacker, dan tester dapat mengira real attacker adalah bagian dari exercise. Source IPs, activity log, timestamps, and escalation contacts membantu deconfliction.

9. Data Handling & Evidence



Evidence lifecycle: collect minimum -> hash -> restrict -> retain/delete sesuai agreement

Evidence bisa berisi screenshot, request/response, command output, logs, PoC code, packet capture, or exported configuration. Treat semua evidence sebagai potentially sensitive. Kumpulkan hanya yang dibutuhkan untuk membuktikan finding dan reproduksi.

Control	Praktik
Minimization	Capture bagian yang relevan, bukan database dump penuh
Labeling	Asset, timestamp, tester, finding/reference ID
Integrity	SHA-256 manifest untuk mendeteksi perubahan
Access	Restrict filesystem/cloud share; least privilege
Secrets	Redact token/password/session key dari report
Retention	Ikuti periode yang disepakati; catat deletion/return
Transfer	Gunakan channel approved dan encryption sesuai policy

Hash limitation

SHA-256 membantu mendeteksi perubahan pada file. Ia tidak membuktikan siapa yang membuat file, apakah file awal benar, atau chain-of-custody secara hukum. Gunakan sesuai kebutuhan engagement.

10. Scope Creep dan Change Control

Scope creep adalah perubahan target, objective, waktu, teknik, atau deliverable yang masuk selama engagement tanpa mekanisme formal. Perubahan bisa valid, tetapi harus menghasilkan approval baru yang jelas.

Minimal change-control record

```
CHANGE REQUEST
ID: CR-002
Reason: new staging API discovered
Requested change: add https://api2.staging.example.invalid
Ownership validated by: <name/role>
Risk/impact: +2 hours testing; no production traffic
RoE impact: same web/API rules
Approved by: <authorized role>
Effective at: <timestamp>
```

Rule

No approval, no test. Jangan menggunakan chat informal yang ambigu sebagai alasan untuk memperluas scope berisiko tinggi.

11. Pre-Engagement Checklist & Kickoff

- [] Authorization approved and accessible.
- [] Objectives and success criteria agreed.
- [] In-scope/out-of-scope inventory versioned.
- [] RoE, testing window, source IPs, prohibited actions agreed.
- [] Contacts and escalation path tested.
- [] Test accounts/MFA/test data prepared.
- [] Backup/monitoring/rollback ownership known.
- [] Evidence handling/retention defined.
- [] Report audience and delivery date defined.
- [] Cleanup/retest expectations defined.

Kickoff bukan formalitas. Gunakan kickoff untuk menghilangkan ambiguity: ulangi objective, scope version, timeline, emergency stop phrase, expected tester source addresses, dan siapa yang dapat approve change.

12. Execution Notes: Time, Asset, Action, Result

Activity log membantu reproduksi, deconfliction, dan incident review. Log tidak harus merekam setiap keystroke, tetapi harus cukup untuk menjawab: kapan, asset apa, tindakan apa, hasil apa, dan finding/evidence mana yang terkait.

Contoh activity log training

```
timestamp_utc,asset,action,result
2026-10-05T02:14:03Z,127.0.0.1,baseline HTTP request,200 OK
2026-10-05T02:18:44Z,127.0.0.1:3000>manual auth flow review,session cookie observed
```

Sensitive logging

Jangan menaruh password, bearer token, session cookie, private key, recovery key, atau secret lain ke activity log. Referensikan evidence ID yang disimpan aman bila memang perlu.

13. Cleanup, Restoration, dan Closure

Pentest yang selesai secara teknis belum selesai secara operasional. Temporary account, uploaded file, test data, configuration change, tunnel, scheduled task, API key, cloud resource, or monitoring exception harus dipulihkan/dihapus sesuai agreement.

- [] Catat semua perubahan yang dibuat selama execution.
- [] Restore setting yang memang diubah untuk test.
- [] Hapus temporary artifacts/accounts/keys sesuai owner approval.
- [] Verify service health setelah cleanup.
- [] Konfirmasi evidence retention/deletion.
- [] Deliver preliminary critical findings bila ada.
- [] Record client/owner closure confirmation.

14. Reporting Expectations Ditentukan Sebelum Testing

OffSec menekankan note-taking dan dokumentasi yang cukup agar langkah dapat direplikasi oleh pembaca teknis. Di real engagement, format report harus disepakati sebelum test: executive summary, scope/methodology, technical findings, evidence, risk, remediation, limitations, and appendices.

Audience	Butuh apa
Executive	Impact bisnis, themes, priorities, residual risk
Engineering	Reproduction, root cause, affected asset, remediation
Security/IR	Attack path, telemetry, controls, detections
Audit/Compliance	Scope, methodology, evidence of testing, limitations

Report accuracy

Jika sesuatu tidak diuji karena out-of-scope, time limit, instability, atau missing credential, tulis sebagai limitation. Jangan membuat pembaca mengira area tersebut sudah dinilai.

15. Hands-on Lab 1 - Buat Engagement Workspace

Objective

Buat folder engagement dengan permission restrictive dan struktur yang konsisten.

```
mkdir -p ~/CyberSec/labs/module06
cd ~/CyberSec/labs/module06
cp <repo>/modules/06-pentest-methodology-scope-roe/labs/engagement-init.sh .
./engagement-init.sh fictional-engagement
find fictional-engagement -maxdepth 2 -type d -print
```

Perhatikan `umask 077`: file/folder baru tidak otomatis world-readable. Ini bukan pengganti encryption, tetapi baseline yang lebih aman untuk local evidence workspace.

16. Hands-on Lab 2 - Define Objective & Success Criteria

Scenario

Lo diminta menilai OWASP Juice Shop lokal pada 127.0.0.1:3000. Tidak ada public target.

Buat `00-admin/objectives.md` dengan tiga bagian: Business Question, Technical Objective, Success/Stop Criteria. Contoh: "Can an unauthenticated local lab user access another user's object?" Jangan menulis objective abstrak seperti "hack sebanyak mungkin".

- ☐ Objective measurable
- ☐ Environment disebut
- ☐ Impact proof minimum
- ☐ Stop condition disebut
- ☐ Out-of-scope implication jelas

17. Hands-on Lab 3 - Scope Matrix

Copy `scope.example.json`, lalu ubah hanya target lokal yang memang lo miliki. Jalankan validator:

```
cp <repo>/labs/scope.example.json fictional-engagement/01-scope/scope.json
python <repo>/labs/validate-scope.py fictional-engagement/01-scope/scope.json
echo $?
```

Eksperimen aman: hapus field `stop\_conditions`, buat malformed URL, atau ubah `in\_scope` menjadi string. Validator harus gagal. Ingat: PASS hanya berarti struktur dokumen lolos, bukan izin legal.

18. Hands-on Lab 4 - Draft Rules of Engagement

Objective

Ubah boundary abstrak menjadi aturan yang dapat dipatuhi saat testing.

Buat `01-scope/roe.md` dengan minimal: authorized source, window+timezone, allowed techniques, prohibited techniques, rate/concurrency bila relevan, account lockout rule, sensitive-data rule, stop conditions, emergency contact, change-control rule, cleanup expectations.

Quality test

Minta diri lo sendiri menjawab: jika service mulai error 500 setelah request tertentu, apakah RoE menjelaskan apakah harus lanjut, pause, atau call siapa?

19. Hands-on Lab 5 - Contact & Escalation Tabletop

Isi `00-admin/contacts.md`, lalu lakukan tabletop tanpa menyerang apa pun. Untuk tiap skenario, tulis keputusan 3-5 langkah:

1. Web lab berhenti merespons setelah testing.
2. Lo menemukan host 10.20.30.9 yang tidak ada di scope.
3. Lo melihat data yang tampak seperti data pelanggan asli.
4. Blue Team menyatakan sedang menangani incident nyata pada waktu yang sama.
5. Product owner meminta lewat chat: "sekalian test production ya".

Jawaban ideal konsisten dengan RoE dan change-control, bukan improvisasi berdasarkan rasa penasaran.

20. Hands-on Lab 6 - Activity Log

```
python <repo>/labs/activity-log.py \
--file fictional-engagement/02-notes/activity-log.csv \
--asset 127.0.0.1 \
--action "scope validation" \
--result "PASS"

cat fictional-engagement/02-notes/activity-log.csv
```

Jangan masukkan token/credential. Gunakan evidence ID atau finding ID kalau perlu menghubungkan activity dengan material sensitif.

21. Hands-on Lab 7 - Evidence Hash Manifest

Buat dummy evidence, hash, ubah file, lalu verifikasi perubahan:

```
cd fictional-engagement
printf 'local training evidence\n' > 03-evidence/EV-001.txt
../evidence-manifest.sh 03-evidence evidence-manifest.sha256
sha256sum -c evidence-manifest.sha256
printf 'changed\n' >> 03-evidence/EV-001.txt
sha256sum -c evidence-manifest.sha256
```

Expected: verifikasi pertama OK, kedua FAILED. Diskusikan apa yang dibuktikan dan tidak dibuktikan oleh hash.

22. Hands-on Lab 8 - Scope Change Request

Scenario

Dalam recon training, lo menemukan `http://127.0.0.1:8088` milik lab sendiri tetapi belum tercantum di scope.

Jangan test. Buat `01-scope/change-CR-001.md` yang menjelaskan reason, asset, ownership evidence, impact timeline, perubahan RoE, approver, effective time. Setelah "approved" secara tabletop, baru update scope version menjadi v1.1.

23. Hands-on Lab 9 - Git untuk Dokumen, Bukan Secret

Gunakan Git untuk versioning scope/RoE template, tetapi jangan commit evidence sensitif. Buat `.gitignore` di lab:

```
03-evidence/
*.pcap
*.pcapng
*.key
*.pem
.env
secrets/
loot/
```

Commit hanya dokumen sanitised: objectives, scope template, RoE, test plan, cleanup checklist. Untuk real client work, ikuti repository/access policy organisasi; public GitHub jelas bukan tempatnya.

24. Hands-on Lab 10 - Kickoff Simulation

Objective

Lakukan pre-flight verbal check sebelum aktivitas teknis berikutnya.

1. Baca objective dan success criteria dalam 60 detik.
 2. Sebutkan scope version dan dua item out-of-scope.
 3. Sebutkan testing window + timezone.
 4. Sebutkan tiga prohibited techniques.
 5. Sebutkan emergency stop contact dan stop phrase.
 6. Sebutkan evidence retention rule.
 7. Sebutkan siapa yang boleh approve scope change.
- Kalau ada satu jawaban yang ambigu, engagement dianggap belum ready.

25. Mini Project - Engagement Pack

Scenario

Siapkan engagement pack untuk local Juice Shop lab. Tidak ada public internet target dan tidak ada real data.

Deliverables wajib:

- [] 00-admin/authorization-note.md (training self-authorization + ownership statement)
- [] 00-admin/objectives.md
- [] 00-admin/contacts.md
- [] 01-scope/scope.json + validator PASS
- [] 01-scope/roe.md
- [] 01-scope/test-plan.md
- [] 02-notes/activity-log.csv
- [] 03-evidence/evidence-manifest.sha256
- [] 05-cleanup/checklist.md
- [] 06-report/report-outline.md

Review pack seolah lo adalah engagement manager. Cari ambiguity sebelum meneruskan ke Module 07 Recon & OSINT.

26. Practical Challenge - Temukan 15 Masalah di RoE Buruk

Review contoh berikut. Jangan melakukan testing berdasarkan dokumen ini; tugasnya hanya critique.

```
Target: company network
Time: this week
Allowed: normal pentest stuff
Passwords: try whatever works
Production: probably okay
DoS: avoid if possible
Data: download samples if useful
Contact: ask John
Scope changes: use judgement
Cleanup: later
```

Cari minimal 15 masalah: ambiguity target, owner/authorization, timezone/window, third-party boundary, prohibited actions, credential policy, production definition, DoS language, data minimization, contact redundancy, stop conditions, change control, source IP, cleanup, reporting, retention, incident deconfliction, dan lain-lain.

27. Engagement Review Checklist

Area	Checklist
Authorization	Approver punya authority; approval merujuk scope/version
Objective	Business question + measurable technical outcome
Scope	Identifiers precise; exclusions & discovered-asset process
RoE	Allowed/prohibited; window; source; rate; stop conditions
Comms	Primary + emergency + escalation cadence
Safety	Backup/rollback/lockout/production considerations
Evidence	Minimization, labeling, hashing, storage, retention
Change	Scope-change approval path
Cleanup	Artifacts, accounts, configs, exceptions
Report	Audience, format, due date, critical-finding process

28. Knowledge Check

1. Apa perbedaan scope dan Rules of Engagement?
2. Mengapa ownership domain tidak otomatis mengotorisasi testing terhadap CDN/SaaS?
3. Apa fungsi success criteria?
4. Kapan discovered asset boleh mulai diuji?
5. Sebutkan lima kategori yang sebaiknya eksplisit di RoE.
6. Apa bedanya testing window dan safety budget?
7. Kenapa timezone harus ditulis?
8. Apa tindakan pertama saat service terganggu?
9. Kenapa Blue Team deconfliction penting?
10. Apa yang dimaksud evidence minimization?
11. Apa yang dibuktikan SHA-256 manifest?
12. Apa yang tidak dibuktikan SHA-256 manifest?
13. Apa itu scope creep?
14. Apa minimal isi change request?
15. Kenapa real credentials tidak boleh masuk Git?
16. Bagaimana account lockout mempengaruhi credential testing?
17. Mengapa limitation harus muncul di report?
18. Kapan pentest dianggap selesai secara operasional?
19. Apa tujuan activity log?
20. Mengapa "normal pentest stuff" bukan RoE yang baik?

29. Exit Criteria

- [] Gue bisa membedakan authorization, SOW, scope, RoE, dan test plan.
- [] Gue bisa membuat scope yang tidak ambigu dan process untuk asset baru.

- [] Gue bisa menulis allowed/prohibited techniques dan stop conditions.
- [] Gue bisa menjalankan tabletop escalation tanpa improvisasi berbahaya.
- [] Gue bisa membuat activity log tanpa membocorkan secret.
- [] Gue bisa membuat/verify evidence SHA-256 manifest dan memahami limitasinya.
- [] Gue bisa membuat change request sebelum memperluas scope.
- [] Gue bisa menutup engagement dengan cleanup dan retention decision.

Gate ke Module 07

Jangan masuk Recon & OSINT sampai lo bisa melihat sebuah target baru dan refleksi bertanya "apakah ini in-scope dan authorized?" sebelum bertanya "bagaimana cara enumerate?".

30. Cheat Sheet

```

ENGAGEMENT PRE-FLIGHT

AUTHORIZATION
  who approved? which scope version? valid when?

OBJECTIVE
  business question -> technical goal -> sufficient proof

SCOPE
  in-scope | out-of-scope | discovered/unknown -> STOP + validate

ROE
  window/timzone | source IP | allowed | prohibited | rate
  account lockout | data handling | stop conditions | emergency contact

EXECUTION
  timestamp | asset | action | result | evidence ID

CHANGE
  request -> ownership -> impact -> approval -> version update

EVIDENCE
  minimize -> label -> hash -> restrict -> reference -> retain/delete

CLEANUP
  accounts | files | configs | keys | cloud resources | exceptions

RULE
  No approval, no test.
  
```

31. Referensi Utama

NIST SP 800-115 - Technical Guide to Information Security Testing and Assessment - Planning, execution, data handling, reporting, dan Appendix B Rules of Engagement.

<https://csrc.nist.gov/pubs/sp/800/115/final>

NIST publication page - Overview resmi tujuan dan cakupan SP 800-115.

<https://www.nist.gov/publications/technical-guide-information-security-testing-and-assessment>

EC-Council CPENT - Penetration Testing Scoping and Engagement - Pre-engagement, RoE, legal/regulatory considerations, test plan, scope creep.

<https://www.eccouncil.org/train-certify/certified-penetration-testing-professional-cpent/>

OWASP Web Security Testing Guide v4.2 - Methodology yang konsisten, reproducible, dan documented untuk web testing.

<https://wstg.owasp.org/v4.2/>

OffSec OSCP+ Body of Knowledge - Pentest lifecycle, note-taking, technical reports, findings dan recommendations.

<https://help.offsec.com/hc/en-us/articles/38543335188756-OSCP-Body-of-knowledge>

OffSec OSCP+ Reporting Requirements - Dokumentasi/report yang cukup untuk menjelaskan hasil assessment.
<https://help.offsec.com/hc/en-us/articles/360046787731-OSCP-Reporting-Requirements>

Next module

Module 07: Reconnaissance & OSINT. Setelah boundary engagement jelas, kita mulai mengumpulkan informasi dengan metodologi passive-first, ownership-aware, dan evidence-driven sebelum active enumeration.

32. Appendix - Minimal RoE Template

```

ENGAGEMENT ID / SCOPE VERSION:
AUTHORIZED BY:
TESTING WINDOW + TIMEZONE:
AUTHORIZED SOURCE IP/VPN:

IN SCOPE:
OUT OF SCOPE:

ALLOWED:
PROHIBITED:
RATE / CONCURRENCY:
ACCOUNT LOCKOUT RULE:
DATA HANDLING RULE:

STOP CONDITIONS:
EMERGENCY CONTACT:
CHANGE APPROVER:

CLEANUP EXPECTATION:
EVIDENCE RETENTION:
REPORT / CRITICAL FINDING CADENCE:
  
```

33. Appendix - Emergency Stop Card

STOP CARD

1) Stop the related activity. 2) Record timestamp, asset, and last safe action. 3) Preserve only minimal troubleshooting evidence. 4) Contact the named emergency owner. 5) Do not resume until explicit approval is recorded. 6) If scope/ownership is uncertain, treat the asset as out-of-scope.

Simpan versi sanitised dari stop card di notes lo. Tujuannya supaya saat situasi tegang, keputusan penting tidak bergantung pada ingatan atau improvisasi.